

ET 8202: INTRODUCTION TO IS SECURITY



Lecture: 06

Access Controls (b) (Authorization)

ACCESS CONTROL (*ISSUES*)

- ❖ **Access Control** actually places restrictions on users in the access and use systems and system resource.
 - ✓ For example, a particular user, or group of users, might only be permitted access to certain files after logging into a system, while simultaneously being denied access to all other resources.
- ❖ Access Control controls how users and systems communicate and interact with one another.
 - ✓ Access controls give organizations the ability to control, restrict, monitor, and protect resource availability.
 - ✓ They protect the systems and resources from unauthorized access and can be a component that participates in determining the level of authorization after an authentication procedure has successfully completed.
- ❖ **User** permissions and rights to the system/system resources may be based on their identity, clearance, and/or group memberships.

Why access control?

- ❖ Access control is needed to preserve the three tenets of information security; confidentiality, Integrity and Availability.
- ❖ The information is not disclosed to unauthorized persons or processes thus preserving **confidentiality**.
- ❖ **Integrity** is preserved through:
 - ✓ The prevention of the modification of information by unauthorized personnel.
 - ✓ The preservation of unauthorized or unintentional modification of information by authorized personnel
- ❖ The system's authorized users have timely and uninterrupted accessed to the information in the system thus preserving **Availability**.

ACCESS CONTROL ELEMENTS

- ❖ Refers to the basic elements of access control: subject, object and access right.
- ❖ **Subject:** Refers to an entity capable of accessing objects.
 - ✓ Can be a user, program, or process that accesses an object to accomplish a task.
 - ✓ When a program accesses a file, the program is the subject and the file is the object.
 - ✓ For a subject to be able to access a resource, it must be identified, authenticated, authorized, and should be held accountable for its actions.
- ❖ **Object:** Refers to a resource to which access is controlled.
 - Generally, an object is an entity used to contain and/or receive information.
 - Examples include files, folders/directories, directory trees, mail boxes, messages, programs and network nodes. More examples:
 - ✓ **Operating System:** Files or Directories
 - ✓ **Database:** Columns, Rows, Tables, or Views
 - ✓ **Printer** , etc.

ACCESS CONTROL ELEMENTS

- ❖ **Access right:** Refers to the way in which a subject may access an object.
 - Access rights could include: Read, Write, Execute, Delete, Create, Search.
 - Examples:
 - ✓ **Applications:** Read, Write, Execute
 - ✓ **Database:** Update, Insert, Delete
 - ✓ **Reports:** Create, View, Print
 - ✓ **Locks:** Open, Close

ACCESS CONTROL (*ISSUES*)

- ❖ **Authentication:** verifying a claim of identity
- ❖ **Authorization:** verifying a claim of permission
- ❖ **Audit:** verifying the occurrence or non occurrence of previous actions.
- ❖ **NOTE:**
 - ✓ **Permission/granting of access right to a resource is called **authorization**.**

Authorization

❖ Authorization

- ❖ Authorization determines whether or not, the proven identity has some set of characteristics associated with it that gives it the right to access the requested resources.
- ✓ This is a core component of every operating system.
 - ✓ It establishes whether a user is authorized to access a particular resource and what actions he is permitted to perform on the resource.
- ✓ Granting access rights to subjects should be based on the level of trust a company has in a subject and the subject's need to access or use the resource.
- ❖ **Authorization:** It is a process by which the user is either granted access/use or disallowed to protected resources.
 - ✓ Only the trusted user can be granted access/use.

Authorization: Access Criteria

❖ **Access criteria can be broken up into:**

❖ **Roles**

❖ **Groups**

❖ **Location**

❖ **Time**

❖ **Transaction Types**

Authorization: Access Criteria

❖ **Access criteria can be broken up into:** *continued*

❖ **Roles**

❖ Here access rights are assigned to a user based on the tasks performed by the user.

❖ **Groups**

❖ Here, access rights are assigned to a group, in which there are several users required to perform certain tasks.

❖ The users are put into a group, then access rights are assigned to the group.

❖ This makes it easier, compared to assigning the access rights to each user.

❖ For example, the Finance group can be granted Read and Write permissions for a file named Payroll.

Authorization: Access Criteria

❖ Access criteria can be broken up into: *continued*

❖ Location

- ❖ Here access rights are restricted based on the location of users.
 - ✓ For example: It can be used to restrict unauthorized individuals from being able to get in and reconfigure the server remotely.
 - ✓ Usually done through network address restrictions.

❖ Time

- ❖ Here access rights are restricted based on time.
 - ❖ Restrict the times that certain actions or services can be accessed/used.

❖ Transaction Types

- ❖ Here access rights are restricted based on what type of actions or commands can be carried out on the data/resource.

Authorization

- **Below are authorization concepts to keep in mind:**

❖ **Authorization Creep**

- ❖ This is when an employee works for a company over time and moves from one department to another and assigned new access rights without the old access rights being reviewed and removed.
- ❖ This should not be the practice.

❖ **Access Control Lists (ACLs)**

- ❖ A list of subjects that are authorized to access a particular object.

❖ **Need to know principle**

- ❖ This is similar to the least privilege principle.
- ❖ It is based on the concept that individuals should be given access only to the information that they absolutely require in order to complete their job duties.

Authorization

❖ Authorization concepts to keep in mind:

Security Principles

- ❖ Least privilege
- ❖ Separation of duties
- ❖ Job rotation
- ❖ Layered security

Security Principles

Least privilege

- ❖ Least privilege means a subject (user, application, or process) should have only the necessary rights and privileges to perform its task with no additional permissions.
- ❖ Users should only have the level of permissions for those resources that is required to carry out the exact operations they need for their jobs and no more.
- ❖ By limiting an subject's privilege, we limit the amount of harm that can be caused.

Security Principles

Separation of duties (SoD) (also known as "Segregation of duties")

- ❖ This is the concept of having more than one person required to complete a task.
 - ❖ High-value or high-risk tasks require two or more different individuals to complete.
 - ❖ Examples
 - ✓ Open a bank vault
 - ✓ Provision of a privileged-access computer account
 - ✓ Change a firewall rule
 - ❖ The benefit is that: no single individual can abuse the system.
 - ❖ Potential drawback is the cost.
 - ✓ **Money** – Must pay two people instead of one.

Security Principles

Job Rotation

- ❖ This refers to the rotation of individuals through different tasks and duties in the organization's Information Technology (IT) department.
- ❖ Benefits of this approach include:
 - ❖ The individuals gain a better perspective of all the elements of how the various parts of the IT department can help or hinder the organization.
 - ❖ Prevents a single point of failure, where only one employee knows mission critical job tasks.
 - ❖ Reduces likelihood that employees will perform inappropriate or illegal actions if they fear being caught when next job rotation occurs.

Security Principles

Layered Security

- ❖ Layered security is an approach that implements multiple layers of controls, each layer providing additional defense.
- ❖ This makes compromising the system to take longer and cost more than its worth.
- ❖ Potential downside is the amount of work it takes to create and then maintain the system.

Access Control Models

- ❖ Access control models are generally concerned with whether subjects can access objects and how this access can occur.
- ❖ They are usually seen as frameworks for implementing and ensuring the integrity of security policies that mandate how information can be accessed and shared on a system and how this access can occur.
- ❖ **Three Main Types**
 - ✓ **Discretionary Access Control (DAC)**
 - ✓ **Mandatory Access Control (MAC)**
 - ✓ **Non-Discretionary (Role Based Access Control)**

Discretionary Access Control (DAC)

- ❖ This is an access control model in which the owner of the object specifies which subjects can access the object. This model is called discretionary because the control of access is based on the discretion (wish) of the owner.
- ❖ The most common implementation of DAC is through *Access Control List (ACL)*.
 - ❖ The ACL is dictated and set by the owners and enforced by the operating system.
 - ✓ The access control list (ACL) lists users and their permitted access rights
 - ✓ Each object on a DAC based system has an ACL associated with it.
 - ✓ An ACL contains a list of users and groups to which the user has permitted access together with the level of access for each user or group.

Mandatory Access Control (MAC)

- ❖ Unlike Discretionary Access Control (DAC) where each user controls the access to their own data, In Mandatory Access Control (MAC), access to system resources (objects) is controlled by the operating system (under the control of a system administrator configured settings).
- ✓ In mandatory access control (MAC), the system (and not the users) specifies which subjects can access specific data objects.
- ✓ It is not possible under MAC enforcement for users to change the access control of a resource.
- ✓ Operating systems enforce the system's security through the use of **security labels**.

Mandatory Access Control (MAC)

- MAC is simply based on **Security labels** (resource sensitivity) and **Security clearances** (access eligibility).
 - It was named mandatory because an entity that has clearance to access a resource may not, just by its own volition (power), enable another entity to access that resource.
 - Mandatory = compulsory
- MAC evolved out of requirements for military information security.

Non-Discretionary (Role Based) Access Control Models

❑ Role Based Access Control (RBAC)

- ❑ Here access rights are decided based on the roles that users have within the system and on rules stating what accesses are allowed to users in the given roles.
- ❑ Simply, based on roles (given to system users) and rules (defines roles' access rights).
 - **Roles and Rules.**
 - Roles – responsibilities
 - Rules – regulations
- ❑ A user (typically a human being) has access to an object based on the assigned role.
- ❑ **Roles** are defined based on job title/functions.
- ❑ RBAC is the best system for a company that has a huge number of employees.

Non-Discretionary (Role Based) Access Control Models

- ❖ Essentially, RBAC assigns permissions to particular roles in an organization.
- ❖ Users are then assigned to that particular role.
 - ✓ For example, an accountant in a company will be assigned to the *Accountant* role, gaining access to all the resources permitted for all accountants on the system.
 - ✓ Similarly, a software engineer might be assigned to the *developer* role.
- ❖ User under RBAC may only be assigned a single role in an organization.
 - ✓ There is no way to provide individual users additional permissions over and above those available for their role.
 - ✓ The accountant described above gets the same permissions as all other accountants, nothing more and nothing less.

DAC vs MAC vs RBAC

Model	Access Control Owner	Sec Policy enforced by
DAC	Data Owners	ACL
MAC	Operating Systems	Security Labels
RBAC	Administrator	Roles/ Functional Position

Access Control Administration

- ❖ First an organization must choose the access control model (DAC, MAC, RBAC) and implement different access control technologies.
- ❖ Access Control Administration comes in two basic forms:
 1. **Centralized**
 2. **Decentralized**

Access Control Administration (1)

Centralized Access Control Administration:

- ❖ Refers to the approach in which one entity is responsible for overseeing access to all corporate resources.
 - ❖ This approach provides a consistent and uniform method of controlling access rights.
- ❖ Types of Centralized Access Control Administration:
 - ✓ **RADIUS**
 - ✓ **TACACS**
 - ✓ **Diameter**

Access Control Administration (2)

❖ **Decentralized Access Control Administration:**

- ❖ Refers to an approach which gives control of access to the people who are closer to the resources.
- ❖ The controller are the people who may better understand who should and should not have access to certain files, data, and other resources.
- ❖ In this approach it is often the functional manager who assigns access control rights to employees.
- ❖ Changes happen faster through this type of administration because not just one entity is making changes for the whole organization.
 - ❖ Because no single entity controls access as a whole, different managers and departments can practice security and access controls in different ways.
 - ❖ This approach has no methods for consistent access control.

Access Control Methods

- ❖ Access controls can be implemented at various layers of an organization, network, and individual systems
- ❖ Three broad categories:
 - ✓ Administrative
 - ✓ Physical
 - ✓ Technical (aka Logical)

Access Control Methods (1)

Administrative Controls

- ❖ Policy and Procedure
- ❖ Personnel Controls
 - ✓ Separation of Duties
 - ✓ Rotation of Duties
 - ✓ Mandatory Vacation
- ❖ Supervisory Structure
- ❖ Security Awareness Training

Access Control Methods (2)

Physical Controls

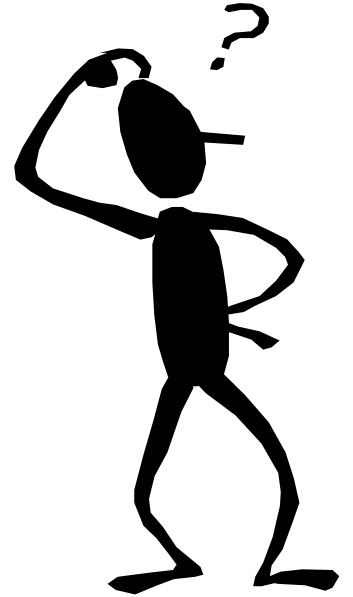
- ❖ Network Segregation
- ❖ Perimeter Security
- ❖ Work Area Separation
- ❖ Data Backups
- ❖ Cabling

Access Control Methods (3)

Technical (Logical) Controls

- ❖ System Access
- ❖ Network Architecture
- ❖ Network Access
- ❖ Encryptions and protocols
- ❖ Auditing

THANK YOU



END

ET 8202: LECTURE 06